

合同与法律合规审查规范

技术规范文件

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

目录

- 1. 概述
- 2. 技术采购合同审查
 - 2.1 常见技术合同类型
 - 2.2 技术部门审查要点
 - 2.3 审查流程
- 3. 保密协议管理
 - 3.1 技术类NDA适用场景
 - 3.2 NDA关键条款
- 4. 开源软件合规
 - 4.1 开源许可类型
 - 4.2 开源管理流程
 - 4.3 保险行业特殊注意事项
- 5. 技术方案合规评估

合同与法律合规审查规范

1. 概述

本文档定义技术部门在涉及合同与法律合规事项中的工作规范，包括技术采购合同审查、技术要求编写、保密协议管理、开源合规等内容。适用于技术采购、供应商管理和项目管理场景。

2. 技术采购合同审查

2.1 常见技术合同类型

合同类型	典型场景	技术部门关注要点
软件采购	购买商业软件许可	许可模式、使用范围、升级维护
软件开发	定制开发外包	知识产权归属、验收标准、源码交付
云服务	IaaS/PaaS/SaaS	SLA、数据主权、出口限制
技术合作	联合研发/技术接入	知识产权共享、保密责任
系统集成	对接第三方系统	接口标准、数据安全、故障责任
维保服务	系统运维支持	响应时间、服务范围、SLA指标

2.2 技术部门审查要点

审查维度	具体检查项
技术要求	功能需求、性能指标、兼容性要求是否明确
交付物	交付清单、交付标准、交付时间是否清晰
验收标准	验收流程、验收标准、验收周期是否可操作
知识产权	源码、文档、数据的归属和使用权
保密义务	保密范围、保密期限、违约责任
服务水平	SLA指标(SLA响应时间、故障恢复时间、可用性)
惩罚条款	未达标的赔偿/扣减条款
数据安全	数据处理权限、存储位置、销毁要求

2.3 审查流程

需求提出 → 需求澄清(沟通+邮件) → 需求确认 → 需求评审 → 需求发布

技术部门签署前需完成：

1. 技术方案评估报告
2. 安全合规评估
3. 知识产权归属确认
4. 验收标准可执行确认

3. 保密协议管理

3.1 技术类NDA适用场景

- 与第三方系统进行技术对接
- 引入外部技术团队参与开发

- 供应商POC测试阶段
- 技术方案招投标

3.2 NDA关键条款

条款	建议标准
保密信息范围	明确列举技术方案、架构文档、源码、数据模型
保密期限	合同期内+合同终止后3年(技术秘密可更长)
例外条款	已公开信息、独立开发、法律要求披露
违约责任	保密违约金+实际损失赔偿
返还/销毁	合同终止后30天内返还或销毁保密信息

4. 开源软件合规

4.1 开源许可类型

许可类型	特点	注意事项
宽松型(MIT, Apache 2.0, BSD)	可任意使用、修改、分发	保留版权声明即可
弱左(CopyLeft)型(LGPL, MPL)	修改后的库需开源，调用可闭源	注意链接方式(动态/静态)
强左型(GPL, AGPL)	衍生作品必须开源	核心业务系统避免使用GPL代码
商业友好型(BSL, Commons Clause)	附加商业限制	需额外购买商业许可

4.2 开源管理流程

需求 → 评估 → 审批 → 登记 → 审计

阶段	操作	工具/方法
代码引入	检查依赖库的许可证类型	Snyk / FOSSA
合规评估	评估许可是否与项目兼容	法务+技术共同评估
审批	有冲突的许可以及新引入License需审批	合规委员会
登记	在开源管理平台登记所有开源组件	SW360 / 自研
审计	定期扫描代码中的开源组件，更新登记表	Trivy / FOSSA

4.3 保险行业特殊注意事项

- 核心精算模块避免使用 GPL/AGPL 许可的开源组件
- 客户数据相关的代码模块确保无传染性许可
- 若修改了 LGPL 代码，需提供修改说明
- 使用 Apache 2.0 组件时需关注专利授权条款

5. 技术方案合规评估

需要法务参与的评估场景：

1. 引入涉及个人信息处理的新技术方案
2. 使用自动化决策技术（AI核保、智能理赔）
3. 涉及跨境数据传输的技术方案
4. 与外部平台深度集成的技术方案
5. 影响保单法律效力的技术变更